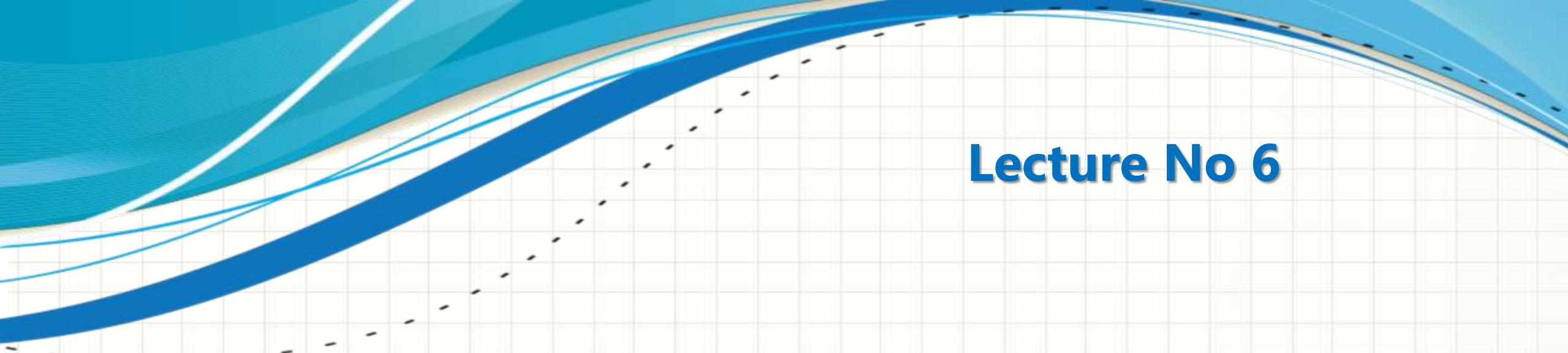




CSC432 – INFORMATION SECURITY

Dr. Muhammad Sharjeel

muhammadsharjeel@cuilahore.edu.pk



Lecture No 6

AUTHENTICATION AND AUTHORIZATION

Authentication



- ☐ Authentication - who you are
- ☐ To verify the identity of a user (or entity) attempting to access a system or resource
- ☐ Common authentication methods
 - ☐ Usernames and passwords
 - ☐ Biometrics (fingerprints, facial recognition)
 - ☐ One-time passwords
 - ☐ Multi-factor authentication

Authorization



- ❑ Authorization – what you can do
- ❑ To determine what actions an authenticated user is allowed to perform and what resources it can access
- ❑ Authorization is often based on roles, permissions, or access control lists (ACLs)

Authentication



Authentication for Computers vs Humans

- ☐ Computer to computer authentication
 - ☐ Computers can remember high-quality cryptographic keys and perform cryptographic operations
- ☐ Human to computer/human authentication
 - ☐ Humans cannot store large keys
 - ☐ Humans cannot accurately or efficiently perform cryptographic operations
- ☐ Need special methods for authenticating people

Passwords



Options for authenticating humans

- ❑ There are three main ways of authenticating an individual (human):
 - ❑ Something you know: A password, cryptographic key, or the correct answer to a challenge-response test
 - ❑ Something you own: A physical key, security card or badge, or a one-time password generator
 - ❑ Something you are: Some biometric measurement (facial features, fingerprint, retina scan, voice print, and so on)

Passwords



What is a Password?

- ☐ Combination of characters (available from keyboard)
- ☐ Should be secure and easy to use

- ☐ Passphrase: sequence of words or text
 - ☐ Spaces allowed
 - ☐ Usually longer than password

Passwords



Problems With Passwords

- ☐ Attacker may see the password when it is used
- ☐ Attacker may read the file where computer stores password
- ☐ A password might be easy to guess
- ☐ A password might be crack-able offline (brute force)
- ☐ A password might be secure, but the system may become too inconvenient to use (e.g., very long password)

Passwords



Online Password Guessing

- ☐ Try to guess the password while system in use
 - ☐ Attacker has only a limited time
 - ☐ Guesses can be recorded/tracked
- ☐ Security depends on:
 - ☐ Number of incorrect guesses allowed
 - ☐ Consequence of too many incorrect guesses
- ☐ Approaches to make system more secure:
 - ☐ Lock system (e.g., account) if too many guesses
 - ☐ Limit the speed that guesses can be made
 - ☐ Try to find the attacker
 - ☐ Make passwords harder to guess

Passwords



Offline Password Guessing

- ☐ Try to guess the password outside of normal operation of system
 - ☐ Attacker has no restrictions on time or computing resources
 - ☐ Guesses are not recorded
- ☐ Passwords are stored on system
 - ☐ Store cryptographic hash of password
 - ☐ Limit read-access to password file/database

Passwords



- ☐ As insecure as passwords generally are, they're not going away anytime soon
- ☐ Every year we have more and more passwords to deal with, and every year they get easier and easier to break
- ☐ We need a strategy, agree ??
- ☐ The best way to explain how to choose a good password is to explain how they're broken

Passwords



- ❑ Generally, the attacks on passwords are based on a model known as an offline password-guessing attack
- ❑ The attacker gets a file of encrypted passwords
- ❑ Turn that encrypted file into unencrypted passwords, by guessing passwords, and then seeing if they're correct
- ❑ Yes, there are ways to foil this attack, and that's why we can still have four-digit PINs on ATM cards, but it's the correct model for breaking passwords
- ❑ There are commercial programs (hacker tools) that do password cracking, and they're really good

Passwords



- ❑ The efficiency of password cracking depends on two largely independent things: power and efficiency
- ❑ Power (computing power) means powerful computers, test more passwords per second
 - ❑ one program advertises eight million per second
- ❑ Efficiency, on the other hand, is the ability to guess passwords cleverly
 - ❑ Try the most common passwords first
 - ❑ It doesn't make sense to run through every eight-letter combination (200 billion possible passwords) from "aaaaaaaa" to "zzzzzzzz", in order

Passwords



- ❑ Typically passwords consists of a root plus an appendage
- ❑ Root not necessarily a dictionary word, but usually something pronounceable
- ❑ An appendage is either a suffix (90% of the time) or a prefix (10% of the time)
- ❑ Examples of root, "letmein" "temp" "123456"
- ❑ Examples of suffix appendages, "1" "4u" "2014" "007" "!"

Passwords



- ❑ Password cracking programs use different dictionaries
 - ❑ English words, names, foreign words, phonetic patterns and so on for roots
 - ❑ Two digits, dates, postal codes, single symbols and so on for appendages
 - ❑ They run the dictionaries with various capitalizations and common substitutions: "\$" for "s", "@" for "a," "1" for "l" and so on
- ❑ Modern password crackers combine different words from their dictionaries
 - ❑ They can be fed with any personal information about the password creator
 - ❑ They can test names and addresses from the address book, meaningful dates, and any other personal information
 - ❑ If you ever saved an e-mail with your password, or kept it in an obscure file somewhere, or if your program ever stored it in memory, they can grab it

Passwords



- ❑ There are schemes for generating passwords, e.g., string together individual words like "correcthorsebatterystaple"
- ❑ No longer good practice (password crackers are on to this trick)
- ❑ Example: A 16,000-entry encrypted password file was provided to three experts, and were asked to break as many as possible
- ❑ The winner got 90% of them, the loser 62%
- ❑ If there's any new news, it's that this kind of thing is getting easier faster than people think
- ❑ **Pretty much anything that can be remembered can be cracked**

Passwords



- ☐ So, what's the solution, how to create a strong (secure) password?
- ☐ Define your own scheme

"So if you want your password to be hard to guess, you should choose something that this process will miss. My advice is to take a sentence and turn it into a password. Something like "This little piggy went to market" might become "tlpWENT2m". That nine-character password won't be in anyone's dictionary. Of course, don't use this one, because I've written about it. Choose your own sentence, 'something personal'."

"Schneier scheme"

Passwords



- ❑ Here are some examples:
- ❑ Wlw7,mstmsritt = When I was seven, my sister threw my stuffed rabbit in the toilet
- ❑ Wow,doestcst = Wow, does that couch smell terrible
- ❑ Ltime@go-inag~faaa! = Long time ago in a galaxy not far away at all
- ❑ uTVM,TPw55:utvm,tpwstillsecure = Until this very moment, these passwords were still secure
- ❑ The idea is to combine a personally memorable sentence with some personally memorable tricks to modify that sentence into a password
 - ❑ Even better is to use random unmemorable alphanumeric passwords

Passwords



There's more to passwords than simply choosing a good one:

- ☐ Never reuse a password you care about
 - ☐ Even if you choose a secure password, the site it's for could leak it because of its own incompetence
 - ☐ You don't want someone who gets your password for one application or site to be able to use it for another
- ☐ Don't bother updating your password regularly
 - ☐ The requirement 90-day (or whatever) password upgrades do more harm than good
 - ☐ Unless you think your password might be compromised, don't change it
- ☐ Beware the "secret question"
 - ☐ This backup system is easier to break than your password
 - ☐ It's smart to use a password manager, or write your passwords on a piece of paper and secure that piece of paper

Passwords



One last piece of advice

"If a site offers two-factor authentication, seriously consider using it"

Authorization



- ❑ What can someone do?
 - ❑ Function of specifying access rights to resources
- ❑ System decides whether access requests from (authenticated) users shall be approved (granted) or disapproved (rejected)

Authorization



Key Terms

- ☐ Policy: a statement of what is, and what is not, allowed
- ☐ A high-level requirements that specifies
 - ☐ how access is managed
 - ☐ who may access, what information
- ☐ Model: provides a formal representation of the access control policy and its working
- ☐ Mechanism: defines the low level (software and hardware) functions
 - ☐ implement the controls imposed by the policy and formally stated in the model
- ☐ Models bridge the wide gap in abstraction between policy and mechanism

Authorization



Lampson 1969

- ❑ Emergence of multiuser environment
 - ❑ people realized the need to prevent interference from each other
- ❑ A basic model was developed
 - ❑ associates users with identities
 - ❑ assigns permissions over system resources based on those identities
- ❑ Lampson
 - ❑ introduced the formal notions of subjects and objects
 - ❑ an access control matrix to hold the access permission

subject - user
object- file, data

Authorization



Bell-LaPadula 1973

- ☐ Formulated the military rules for military security applications into a mathematical model
 - ☐ military security form a hierarchy
 - ☐ higher rank documents are only accessible to higher rank officials
- ☐ Bell-LaPadula
 - ☐ introduced the multilevel secure system
 - ☐ users are only allowed to access information which is classified as lower than their own security clearance
 - ☐ confidential information is restricted only to the higher ranked officials

Authorization



Biba Integrity 1977

- ☐ Alternative to Bell-LaPadula that offer integrity
- ☐ Allows a subject to read an object, if the object has greater security level than the subject
- ☐ A subject can only write to an object if the security level of the subject is higher than the object
- ☐ An object can only be written from the higher levels and read from the lower levels

Authorization



DoD 1985

- ☐ United States Department of Defense (DoD) published its own standards for military and personal applications, commonly known as
- ☐ MAC (Mandatory Access Control)
 - ☐ one administrator who controls every system resource and manages its access for all the users in the system
- ☐ DAC (Discretionary Access Control)
 - ☐ support ownership, local control and other requirements of personal applications

Authorization



Clark Wilson 1987

- ❑ Introduces two central concepts
 - ❑ Well-formed transaction
 - ❑ constraints the user to modify data only in authorized way
 - ❑ Separation of Duty (SoD)
 - ❑ ensures that every critical operation must be completed by at least two users

Authorization



Brewer and Nash 1989

- ☐ Distributes objects in company wise dataset and categorized them into conflict of interest circles
- ☐ A subject can read an object if
 - ☐ the object belongs to the same dataset from which the subject has previously read
 - ☐ the subject had not read some other object from the same conflict of interest circle

Authorization



Role based access control 1992

- ☐ Introduces system wide roles which were assigned permissions over resources
- ☐ In order to access a resource
 - ☐ User needs to be a part of some role
 - ☐ Role must have access rights over the requested resource
- ☐ It supports context, for instance
 - ☐ Banking system
 - ☐ access decisions at day should be different than the same decisions at night
 - ☐ Military applications
 - ☐ some decision at war may be completely different than the same decision during peace times

Authorization



Distributed Role-Based Access Control 2022

- ☐ Introduced when the software systems were extended to cross domains
- ☐ Agreement of all the companies over rights associated to some role existing in multiple domains
- ☐ Working rights of one role of one company are restricted to its domain only, which makes the situation more complex
- ☐ dRBAC solution supports maintaining separate system domains for each company in the collation

Authorization



Evolution of Access Control

Application	Requirements	Model
Mainframe computers	Time sharing, Prevent users from interfering	Lampson
Military applications	Users' clearance, Multilevel security	Bell-LaPadula
Military applications	Hierarchy of users, confidentiality, secure system state, Admin control	MAC
Personal applications	Ownership, No administrator, user control	DAC
Commercial applications	Integrity, Separation of duties, well-formed transaction	Clark Wilson
Commercial and government organizations	System wide roles, complexity, user overhead, organizational structures	RBAC
Organizations	Context aware, situation based	Rule based
Collation environment	Security and availability in overlapping domains	dRBAC

References



- ❑ Choosing a Secure Password

<http://boingboing.net/2014/02/25/choosing-a-secure-password.html>

- ❑ How much has password cracking improved?

<http://www.lightbluetouchpaper.org/2012/09/03/password-cracking-part-i-how-much-has-cracking-improved/>

<http://www.lightbluetouchpaper.org/2012/09/04/password-cracking-part-ii-when-does-password-cracking-matter/>

- ❑ New Password Cracking software tries 8 Million Times Per Second

<http://hackersnewsbulletin.com/2013/09/new-password-cracking-software-tries-8-million-times-per-second-crack-password.html>

- ❑ The 25 most common passwords of 2013

<http://www.cbsnews.com/news/the-25-most-common-passwords-of-2013/>

- ❑ How crackers ransack passwords

<http://arstechnica.com/security/2013/05/how-crackers-make-minced-meat-out-of-your-passwords/>

References



- ☐ Password crackers (tools)
- ☐ John the Ripper (<http://www.openwall.com/john/>)
- ☐ Hashcat (<http://hashcat.net/oclhashcat/>)
- ☐ Pwdump7 (<http://www.openwall.com/passwords/microsoft-windows-nt-2000-xp-2003-vista-7>)



THANKS